HỆ THỐNG CÔNG NGHỆ SYNAPES
TRUNG TÂM BẢO MẬT & AN TOÀN DỮ LIỆU

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc lập - Tự do - Hạnh phúc

Số: 02/2026/CSBM-SYNAPES/DATA-API

Hà Nội, ngày 05 tháng 11 năm 2026

CHÍNH SÁCH BẢO VỆ DỮ LIỆU CÁ NHÂN
VÀ TIÊU CHUẨN AN TOÀN BẢO MẬT TOKEN API KẾT NỐI

(Tuân thủ Nghị định 13/2023/NĐ-CP và Tiêu chuẩn mật mã học AES-256)

CĂN CỨ PHÁP LÝ VÀ TIÊU CHUẨN KỸ THUẬT ÁP DỤNG:

- *Căn cứ Hiến pháp nước Cộng hòa Xã hội Chủ nghĩa Việt Nam năm 2013 quy định quyền bảo vệ đời sống riêng tư và bí mật cá nhân;*
- *Căn cứ Luật An toàn thông tin mạng số 86/2015/QH13 ngày 19 tháng 11 năm 2015 của Quốc hội;*
- *Căn cứ Luật An ninh mạng số 24/2018/QH14 ngày 12 tháng 06 năm 2018 của Quốc hội;*
- *Căn cứ Nghị định số 13/2023/NĐ-CP ngày 17 tháng 04 năm 2023 của Chính phủ về bảo vệ dữ liệu cá nhân;*
- *Căn cứ Tiêu chuẩn quốc gia TCVN 11930:2017 về công nghệ thông tin - các kỹ thuật an toàn - yêu cầu cơ bản về an toàn hệ thống thông tin theo cấp độ;*
- *Căn cứ Tiêu chuẩn an toàn thông tin quốc tế ISO/IEC 27001:2022 và Tiêu chuẩn mã hóa FIPS 140-3.*

Điều 1. Nguyên tắc thu thập và xử lý dữ liệu hợp pháp

1. Toàn bộ hoạt động thu thập, ghi nhận, xử lý và lưu trữ thông tin trên hệ thống SYNAPES Auto Tool đều tuân thủ chặt chẽ các nguyên tắc cơ bản theo quy định tại Điều 3 Nghị định số 13/2023/NĐ-CP:

- Nguyên tắc hợp pháp, công khai và minh bạch;
- Nguyên tắc giới hạn mục đích: Dữ liệu chỉ được xử lý đúng theo phạm vi tự động hóa và hỗ trợ xuất bản nội dung số do Khách Hàng yêu cầu;
- Nguyên tắc giảm thiểu dữ liệu: Hệ thống tuyệt đối không thu thập các thông tin nhạy cảm nằm ngoài phạm vi kỹ thuật cần thiết;
- Nguyên tắc bảo mật, toàn vẹn: Áp dụng các biện pháp kỹ thuật số hiện đại nhất nhằm ngăn chặn hành vi truy cập trái phép, sửa đổi, tiết lộ hoặc hủy hoại dữ liệu.

Điều 2. Tiêu chuẩn mã hóa Token API OAuth 2.0

1. Hệ thống giao tiếp với các máy chủ dịch vụ của bên thứ ba (Google Cloud, YouTube Data API v3, Meta Graph API, TikTok Open Platform) thông qua giao thức phân quyền OAuth 2.0 chuẩn quốc tế.
2. Toàn bộ mã ủy quyền (Access Token) và mã làm mới (Refresh Token) được cấp bởi các nền tảng mạng xã hội đều được mã hóa đối xứng cấp độ quân sự theo thuật toán **AES-256-GCM (Advanced Encryption Standard with Galois/Counter Mode)** trước khi lưu trữ vào hệ thống cơ sở dữ liệu.
3. Khóa giải mã Master Key được bảo quản trong phân vùng bảo mật riêng biệt (KMS - Key Management Service). Không một kỹ sư, lập trình viên hay cá nhân nào thuộc đơn vị vận hành có quyền xem, can thiệp hoặc giải mã thủ công các Token phân quyền này của Khách Hàng.

Điều 3. Cơ chế bảo vệ mật khẩu đăng nhập của Khách Hàng

1. Mật khẩu do Khách Hàng thiết lập trên giao diện Studio được băm một chiều kết hợp muối ngẫu nhiên (Salted hash) bằng thuật toán chuẩn **bcrypt**.
2. Hệ thống hoàn toàn không lưu trữ mật khẩu dưới dạng văn bản thuần (plain-text). Bên Cung Cấp cam kết trên bất kỳ bảng biểu điện tử, Google Sheet liên kết hay nhật ký hệ thống (logs) nào đều không xuất hiện chuỗi mật khẩu thật của Khách Hàng.

Điều 4. Phạm vi phân quyền tối thiểu đối với dịch vụ Google Drive

1. Khi Khách Hàng ủy quyền lưu trữ video tự động lên tài khoản Google Drive cá nhân, hệ thống chỉ yêu cầu phạm vi quyền tối thiểu duy nhất là: `https://www.googleapis.com/auth/drive.file`.
2. Căn cứ theo đặc tả kỹ thuật của Google, phạm vi quyền `drive.file` giới hạn nghiêm ngặt ứng dụng chỉ có quyền đọc, ghi, chỉnh sửa và tạo mới các tệp tin hoặc thư mục do chính ứng dụng SYNAPES Auto Tool tạo ra. Hệ thống hoàn toàn KHÔNG có quyền truy cập, đọc trộm, sao chép hay chỉnh sửa bất kỳ tệp tin, hình ảnh, tài liệu cá nhân nào khác vốn có trên tài khoản Google Drive của Khách Hàng.

Điều 5. Quyền của chủ thể dữ liệu

Căn cứ Điều 9 Nghị định 13/2023/NĐ-CP, Khách Hàng với tư cách là chủ thể dữ liệu có đầy đủ các quyền:

- Quyền được biết và được thông báo về các hoạt động xử lý dữ liệu liên quan;
- Quyền truy cập, kiểm tra và yêu cầu điều chỉnh thông tin kỹ thuật của mình;
- Quyền rút lại sự đồng ý hoặc thu hồi ủy quyền Token bất cứ lúc nào thông qua trang quản lý ứng dụng của Google, Facebook hoặc TikTok;
- Quyền yêu cầu xóa bỏ hoàn toàn dữ liệu (Right to be forgotten) trên máy chủ SYNAPES khi chấm dứt sử dụng dịch vụ.

Điều 6. Cam kết ứng phó sự cố an ninh mạng

1. Hệ thống thực hiện việc sao lưu dữ liệu dự phòng mã hóa định kỳ mỗi ngày một lần.
2. Trong trường hợp xảy ra sự cố an ninh mạng hoặc hành vi tấn công trái phép đe dọa dữ liệu cá nhân, Bên Cung Cấp có trách nhiệm thông báo cho Cục An ninh mạng và phòng, chống tội phạm sử dụng công nghệ cao (A05) - Bộ Công an và gửi cảnh báo trực tiếp cho Khách Hàng trong vòng 72 giờ theo đúng quy định tại Điều 23 Nghị định 13/2023/NĐ-CP.

NƠI NHẬN:
- Cơ quan quản lý dữ liệu cá nhân Bộ Công an (để báo cáo);
- Chủ thể dữ liệu / Khách hàng sử dụng dịch vụ;
- Đội ngũ Bảo mật thông tin (CISO Office);
- Lưu: Hồ sơ tuân thủ an toàn thông tin số 02/2026.

TRƯỞNG BAN BẢO MẬT HỆ THỐNG
(Ký xác thực và bảo lưu chứng chỉ bảo mật số)

TRUNG TÂM BẢO VỆ DỮ LIỆU SYNAPES